



PDI 2026 | TRILHA 06 | ATIVIDADE 3

Gestao de segredos e rotacao de credenciais

Autor: PDI Marcos Luciano - marcosluciano.rodrigues@v4company.com

Unidade: FV Marketing / V4 Company: Automação & Infraestrutura

Módulo: 06 | Governanca de IA e Seguranca

Data: Setembro 2026

Status: NÃO PUBLICADO · Desenvolvido / Homologação pendente

Versão: 1.0

pdi-governanca-ia-seguranca-a3

1. Contexto

Tokens de Meta Ads, Google, CRM, banco e webhooks circulam entre workers, CIs e maquinas do time sem inventario, sem dono e sem prazo de troca. Chave sem dono e chave eterna.

Esta atividade fecha a causa: **cofre central, entrega por referencia, rotacao com prazo e varredura que falha o build.**

2. Diagnóstico

Segredo em chat, planilha ou commit da acesso a verba de midia e base de leads; a troca emergencial vira madrugada porque ninguem sabe onde cada chave esta usada. O custo do vazamento e proporcional ao tempo de exposicao, e hoje esse tempo e indefinido.

SINTOMA	RISCO	CORRECAO
---------	-------	----------

.env no chat ou wiki	Exposicao permanente	Cofre + referencia
Chave estatica no CI	Abuso silencioso	OIDC ou rotacao curta
Sem rotacao	Janela infinita	30/90/180 dias com dono

3. Solução

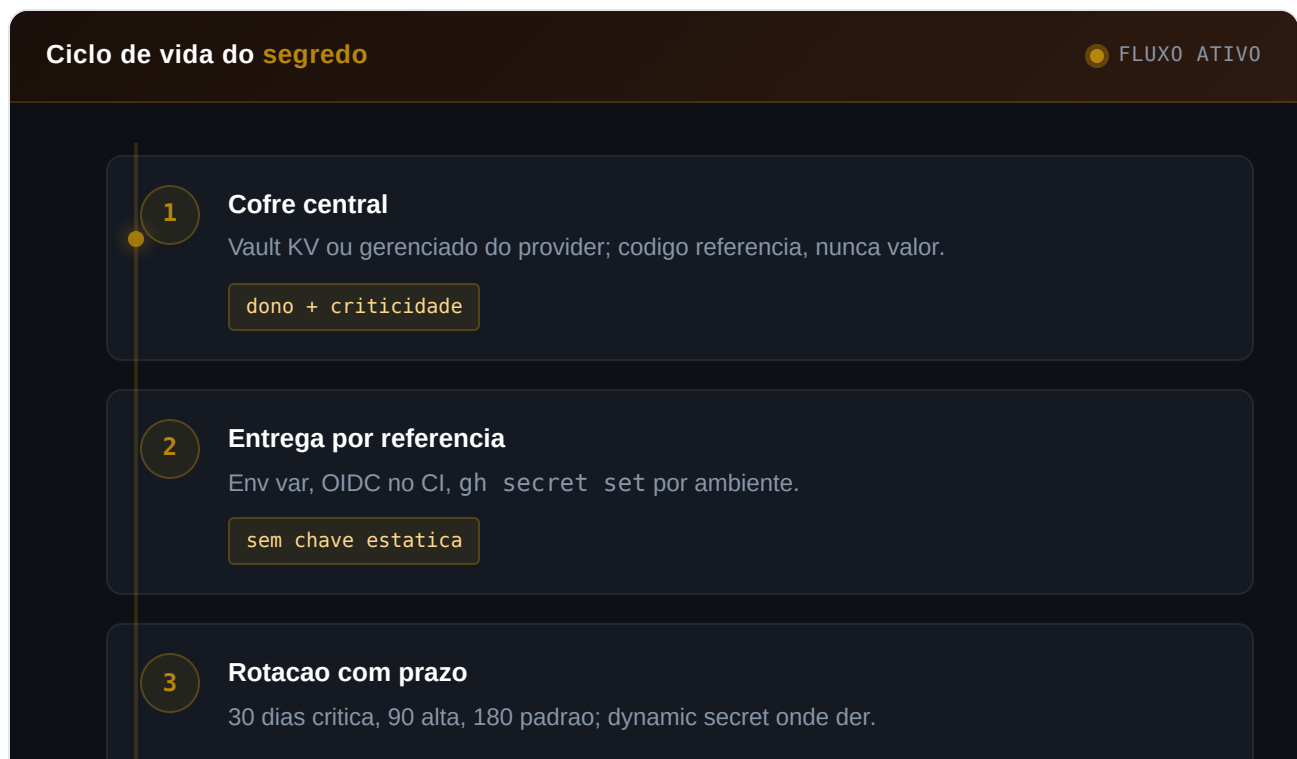
Standard com principios, tabela de guarda e entrega, prazos e resposta a vazamento em 5 passos.

Codigo `secrets_audit.py` executavel: 5 familias de padroes reais, checagem de `.gitignore` e exit code para o CI. Comandos do GitHub Docs verificados na entrega.

```
gh secret set NOME_DO_SECRET
gh secret set NOME_DO_SECRET < secret.txt
gh secret set --env PROD NOME_DO_SECRET
gh secret list
```

- Producao no cofre, CI em secrets por ambiente, local em `.env`` fora do git
- Dynamic secrets com TTL onde o provider suporta

4. Como funciona



gerar, validar, revogar

4

secrets_audit.py

varre

5 padroes reais + .gitignore; achado falha o build.

exit 1 = CI vermelho

5

Vazou, gira

Revogar, girar, auditar uso, comunicar, post-mortem. Crítica em 4 h.

procedimento ensaiado

secrets_audit.py | self-test: AKIA + ghp detectados

comandos do GitHub Docs

5. Entregas

ARQUIVO	CONTEUDO
1-standards/STANDARD-SEGREDOS-ROTACAO.md	Principios, guarda e entrega, rotacao, resposta
2-implementacao/secrets_audit.py	Varredura executavel com self-test passando
2-implementacao/CHECKLIST-SEGREDOS.md	Higiene mensal, 8 itens
7-apresentacao/	Deck de 12 slides, demo, roteiro com 5 Q and A, este relatorio em HTML, DOCX e PDF

6. Métricas de sucesso

METRICA	ATUAL	META
Criticas com rotacao	0% (baseline desta PDI)	100% em 90 dias (meta)
Segredos em repos	a medir na primeira rodada	0 apos remediacao (meta)

Giro de chave vazada	sem rotina	ate 4 h (meta)
----------------------	------------	----------------

Status: Desenvolvido em Setembro 2026, homologacao pendente: migrar Ads e CRM para o cofre e ligar a varredura no CI.